

CSI ORIGIN 2026

PROBLEM STATEMENT

1 PROBLEM STATEMENT

Hackathon / Event Name : CSI ORIGIN 2026

Problem Statement ID : 9

Title : Privileged Access Misuse & Insider Threat Detection

2 BACKGROUND

Current Situation / Context

Financial institutions and enterprises grant privileged access to employees, administrators, service accounts, and automated systems to perform critical operations such as moving funds, modifying payment instructions, approving transactions, accessing sensitive financial data, changing account permissions, and managing financial infrastructure.

Traditional security systems primarily focus on preventing unauthorised access through authentication, access controls, and perimeter defences. However, once a privileged user or service account has successfully authenticated, subsequent actions may appear legitimate even when the account has been compromised, abused by an insider, or manipulated into performing malicious activity.

Underlying Problem or Need

The fundamental gap is the inability of conventional access-control systems to reliably distinguish between legitimate use of privileged access and illegitimate behaviour performed through legitimate credentials.

An account may possess valid permissions to perform individual actions, while the overall sequence, timing, target, frequency, or context of those actions may indicate malicious or compromised behaviour.

The system therefore needs to continuously understand behavioural patterns and operational context associated with privileged financial access rather than evaluating permissions alone.

Why This Is Becoming Important

Privileged accounts have access to highly sensitive financial systems and can potentially perform high-impact operations without triggering conventional authentication controls.

An attacker or malicious insider may deliberately remain within apparently valid permissions while gradually modifying beneficiary information, accessing sensitive customer records, altering transaction limits, creating unauthorised accounts, or initiating fraudulent payments.

This makes continuous behavioural analysis increasingly important for protecting critical financial infrastructure.

Limitations of the Current Situation

Traditional identity and access-management systems can determine who has access to a resource and what permissions that identity possesses. They are generally less capable of determining whether the identity is using those permissions in a manner consistent with its legitimate operational responsibilities.

Evaluating individual actions independently can also fail to reveal coordinated attacks. Multiple actions may each be technically authorised while their combined sequence represents highly suspicious behaviour.

Impact of Leaving This Unresolved

If privileged activity is evaluated primarily through static permissions and individual events, compromised accounts and malicious insiders may remain undetected while performing harmful financial operations.

This can result in fraudulent transactions, unauthorised configuration changes, sensitive-data exposure, privilege abuse, and material financial or operational damage.

3 PROBLEM

What Is Going Wrong / Missing?

Existing security mechanisms can establish whether a user or service account is authorised to perform an action, but they do not necessarily establish whether that action is consistent with the identity's legitimate behaviour and operational context.

The missing capability is a continuous behavioural security layer capable of correlating actions across time, resources, transactions, permissions, counterparties, and contextual signals to identify suspicious behavioural sequences.

The system must distinguish between:

Authorized Access → **Authorized Behaviour**

Authorized Access → **Suspicious / Malicious Behaviour**

Who or What Is Affected?

The problem affects financial institutions and enterprises that provide privileged access to employees, administrators, service accounts, and automated systems.

It affects financial accounts, payment systems, customer data, transaction infrastructure, account permissions, configurations, and other critical resources accessible through privileged identities.

Why Is It Difficult or Important?

The central challenge is that legitimate and malicious activity can originate from the same valid identity and may use the same authorised permissions.

The system must therefore reason across sequences and context rather than simply flagging individual unusual events. It must also minimise false positives because employees may legitimately perform exceptional operations during incidents, audits, maintenance activities, or other business-critical situations.

Effective detection consequently requires understanding role-specific behaviour, peer-group patterns, historical activity, and relevant business context.

Consequences

If this problem remains unresolved, malicious insiders and compromised privileged accounts may be able to operate within legitimate permissions for extended periods without detection.

Security teams may discover incidents only after financial loss, sensitive-data exposure, fraudulent configuration changes, or other material damage has occurred.

4 CHALLENGE

Design and build an intelligent insider-threat detection and response system capable of continuously analysing privileged financial access, correlating behavioural sequences and contextual signals, and identifying activity that may indicate insider misuse or account compromise.

The system should establish behavioural baselines for privileged identities, detect meaningful deviations, investigate contextual risk, and dynamically respond through increased monitoring, privilege restriction, action suspension, additional verification, or escalation.

The System Should Operate as a Continuous Security Loop

Observe → Establish Behavioural Baseline → Correlate Actions → Detect Anomaly → Assess Risk → Investigate Context → Respond → Learn

Problem Requirements / Constraints

1. The system must establish behavioural baselines for privileged users, service accounts, and automated systems based on their roles and historical activity.
2. The system must analyse signals including identity, role, privilege level, transaction behaviour, access timing, resource access, permission changes, beneficiary relationships, data access, and action sequences.
3. The system must correlate multiple actions over time and identify suspicious behavioural sequences rather than evaluating every action independently.
4. The system must detect deviations from role-specific and peer-group behavioural patterns while accounting for legitimate exceptional activity.
5. The system must assess contextual risk using relevant historical incidents, known risk indicators, business context, and relationships between users, resources, accounts, and counterparties.
6. The system must support graduated responses based on assessed risk, including increased monitoring, privilege restriction, action suspension, additional verification, or security-team escalation.
7. The system must continuously incorporate new behavioural observations and incident outcomes to improve future detection and reduce unnecessary false positives.

5 ANNEXURE — DETAILED RULES / CONSTRAINTS

Identity and Privilege Context

The system must consider the identity, role, privilege level, and historical use of each account when assessing activity. An action should not be evaluated independently of the authority and responsibilities associated with the account.

Behavioural Baselines

The system should establish behavioural expectations for different identities and roles using historical activity. Baselines should account for legitimate differences between users, service accounts, and operational functions.

Sequence and Correlation Analysis

The system must evaluate relationships between actions across time. A sequence of individually authorised actions may represent a materially different risk from any single action considered independently.

Business Context

The system must account for legitimate exceptional activity, including incidents, audits, maintenance, operational emergencies, and other business-critical events. Unusual activity should not automatically be treated as malicious.

Financial Activity

The system should consider financial characteristics such as transaction amounts, frequencies, beneficiaries, counterparties, payment configurations, account changes, and transaction limits when assessing privileged behaviour.

Data and Resource Access

Access to sensitive customer records, financial resources, accounts, configurations, and other critical systems should be evaluated in relation to the user's normal operational responsibilities.

Graduated Response

The system should apply proportionate responses based on assessed risk. Responses may include:

Low Risk → Continue Monitoring

Moderate Risk → Additional Verification / Increased Monitoring

High Risk → Restrict / Suspend / Escalate

False-Positive Reduction

The system must distinguish legitimate unusual behaviour from genuinely suspicious activity wherever possible. Role-specific baselines, peer-group behaviour, historical patterns, and business context should contribute to risk assessment.

Continuous Learning

The system should incorporate confirmed incidents, investigation outcomes, and subsequent behavioural observations into its understanding of privileged identities and emerging threat patterns.

6 FINAL PROBLEM CONSTRAINTS

- The system must distinguish between authorised access and authorised behaviour.
- Detection must consider behavioural sequences and contextual relationships rather than relying solely on individual anomalous actions.
- The system must account for identity, role, privilege level, transaction behaviour, access patterns, resource usage, permission changes, counterparties, and historical activity.
- The system must minimise false positives by accounting for role-specific behaviour, peer-group patterns, and legitimate exceptional business activity.
- The system must provide graduated responses appropriate to assessed risk, including monitoring, additional verification, restriction, suspension, and escalation.
- The system must continuously incorporate new observations and incident outcomes to improve detection.
- The challenge is focused on continuous behavioural trust for privileged financial access, not merely identity authentication, static access control, or conventional perimeter security.